LAPORAN AUDIT KEAMANAN WEBSITE

Spencer Web Security Audit Tool

Target Website	www.bumn.go.id
URL Lengkap	https://www.bumn.go.id/
Tanggal Audit	21 May 2026, 11:50:49 WIB
Metode	OWASP Top 10 + CVSS Scoring
Tool	SpencerWeb v2.0
Durasi Scan	603.84 detik

SECURITY GRADE: F **SKOR: 7/100**

1. RINGKASAN EKSEKUTIF

Audit keamanan website **www.bumn.go.id** telah dilakukan pada tanggal **21 May 2026, 11:50:49 WIB** menggunakan Spencer Web Security Audit Tool. Audit ini menggunakan metodologi OWASP Top 10 dengan sistem penilaian risiko CVSS yang disederhanakan menjadi grade A-F.

Berdasarkan 74 pengecekan keamanan yang dilakukan, sistem mendapat grade **F** dengan skor **7/100**. Ditemukan total **27 kerentanan** yang terdiri dari:

Severity	Jumlah	Dampak
CRITICAL	0	Risiko tertinggi, harus segera diperbaiki
HIGH	1	Risiko tinggi, perbaiki dalam waktu dekat
MEDIUM	20	Risiko sedang, jadwalkan perbaikan
LOW	6	Risiko rendah, perbaikan opsional

2. METODOLOGI AUDIT

Audit ini dilakukan menggunakan pendekatan **Black-box Testing** — auditor tidak memiliki akses ke source code maupun infrastruktur internal, dan hanya berinteraksi dengan target sebagaimana attacker dari luar.

Framework yang digunakan:
• **OWASP Top 10** — standar industri untuk web application security testing
• **OWASP Testing Guide v4** — panduan teknis pengujian per kategori
• **CVSS v3.1** — Common Vulnerability Scoring System untuk penilaian risiko

Module yang dijalankan:
1. HTTP Security Headers Audit (Passive)
2. SSL/TLS Certificate Audit (Passive)
3. Sensitive File Exposure Scan (Passive)
4. CMS Detection & Version Check (Passive)
5. WordPress Plugin & Theme Scanner (Passive)
6. SQL Injection Scanner — Error, Boolean, Time-based (Active)
7. Reflected XSS Scanner (Active)
8. Stored XSS Scanner (Active)
9. CSRF Protection Checker (Active)
10. Open Port Reconnaissance (Active)

3. TEMUAN KERENTANAN

Temuan #1: Cookie: XSRF-TOKEN (session)	HIGH
Deskripsi:	Cookie 'XSRF-TOKEN' memiliki 1 masalah: Missing Secure flag
Rekomendasi:	Set flag: Secure pada cookie 'XSRF-TOKEN'

Temuan #2: Cookie: XSRF-TOKEN	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #3: Cookie: portal_publik_kementerian_bumn_session	MEDIUM
Deskripsi:	Cookie tidak aman: Missing 'Secure' flag, Missing 'HttpOnly' flag
Rekomendasi:	Set flag Secure dan HttpOnly pada semua cookie sensitif

Temuan #4: CORS: Wildcard Origin [/]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #5: CORS: Wildcard Origin [/penggerak/detail/pengelola-korporasi-berskala-global-1883145967]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #6: CORS: Wildcard Origin [/penggerak/detail/akselerator-proyek-strategis-nasional-1105670322]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #7: CORS: Wildcard Origin [/penggerak/detail/pemberdayaan-pelibatan-masyarakat-1582343292]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #8: CORS: Wildcard Origin [/penggerak/detail/kinerja-bumn-terus-menguat-1841216925]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #9: CORS: Wildcard Origin [/portofolio/aset/Aset]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #10: CORS: Wildcard Origin [/publikasi/berita/galeri]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #11: CORS: Wildcard Origin [/profil/penghargaan]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #12: CORS: Wildcard Origin [/publikasi/berita/kabar-bumn]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #13: CORS: Wildcard Origin [/profil/erabarukami/lima-pilar-prioritas]	MEDIUM
Deskripsi:	Access-Control-Allow-Origin: * — semua domain diizinkan akses.
Rekomendasi:	Ganti wildcard (*) dengan domain spesifik yang diizinkan.

Temuan #14: Clickjacking: /	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #15: Clickjacking: /penggerak/detail/pengelola-korporasi-berskala-global-1883145967	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #16: Clickjacking: /penggerak/detail/akselerator-proyek-strategis-nasional-1105670322	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #17: Clickjacking: /penggerak/detail/pemberdayaan-pelibatan-masyarakat-1582343292	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #18: Clickjacking: /penggerak/detail/kinerja-bumn-terus-menguat-1841216925	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #19: Clickjacking: /portofolio/aset/Aset	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #20: Clickjacking: /publikasi/berita/galeri	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #21: Clickjacking: /profil/penghargaan	MEDIUM
Deskripsi:	Halaman bisa di-embed dalam iframe (clickjacking). Missing: CSP frame-ancestors. Attacker bisa overlay halaman ini dengan UI palsu.
Rekomendasi:	Tambahkan X-Frame-Options: DENY (atau SAMEORIGIN) DAN Content-Security-Policy: frame-ancestors 'self'

Temuan #22: Server (Info Leak)	LOW
Deskripsi:	Terdeteksi: elb — Membocorkan versi web server (misal: Apache/2.4.41)
Rekomendasi:	Sembunyikan atau hapus header Server dari response

Temuan #23: Info Leak: Email Address [/]	LOW
Deskripsi:	Email address ditemukan di source code — bisa digunakan untuk phishing/spam. Value (masked): pend****o.id
Rekomendasi:	Jangan hardcode email di HTML. Gunakan form kontak atau obfuscation.

Temuan #24: Directory: /auth	LOW
Deskripsi:	Path /auth accessible (HTTP 302, 1202 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #25: Directory: /robots.txt	LOW
Deskripsi:	Path /robots.txt accessible (HTTP 200, 24 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #26: security.txt (missing)	LOW
Deskripsi:	security.txt tidak ditemukan — best practice adalah menyediakan file ini agar security researcher tahu cara melaporkan kerentanan
Rekomendasi:	Buat file /.well-known/security.txt sesuai RFC 9116. Minimal berisi Contact: dan Expires: fields.

Temuan #27: WAF Detection	LOW
Deskripsi:	Tidak terdeteksi WAF (Web Application Firewall) — website mungkin tidak menggunakan layer proteksi tambahan
Rekomendasi:	Pertimbangkan menggunakan WAF seperti Cloudflare, AWS WAF, atau ModSecurity untuk proteksi tambahan terhadap serangan web

4. DETAIL HASIL PER MODULE

Module 1 — HTTP Security Headers

Passed: **8** | Failed: **3** | Total: **11**

Check	Severity
Server (Info Leak)	LOW
Cookie: XSRF-TOKEN	MEDIUM
Cookie: portal_publik_kementerian_bumn_session	MEDIUM

Module 2 — SSL/TLS Certificate

Passed: **6** | Failed: **0** | Total: **6**

Module 3 — Sensitive File Exposure

Passed: **35** | Failed: **0** | Total: **35**

Module 4 — CMS Detection

Passed: **1** | Failed: **0** | Total: **1**

Module 6 — Advanced SQL Injection

Passed: **1** | Failed: **0** | Total: **1**

Module 7 — Reflected XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 9 — CSRF Protection

Passed: **20** | Failed: **0** | Total: **20**

Module 10 — Port Reconnaissance

Passed: **1** | Failed: **0** | Total: **1**

5. KESIMPULAN DAN SARAN PRIORITAS

Berdasarkan hasil audit, website **www.bumn.go.id** memiliki **0 kerentanan CRITICAL** dan **1 kerentanan HIGH** yang memerlukan perhatian segera.

Saran prioritas perbaikan:

1. [HIGH] Cookie: XSRF-TOKEN (session)
Set flag: Secure pada cookie 'XSRF-TOKEN'

2. [MEDIUM] Cookie: XSRF-TOKEN
Set flag Secure dan HttpOnly pada semua cookie sensitif

3. [MEDIUM] Cookie: portal_publik_kementerian_bumn_session
Set flag Secure dan HttpOnly pada semua cookie sensitif

4. [MEDIUM] CORS: Wildcard Origin [/]
Ganti wildcard (*) dengan domain spesifik yang diizinkan.

5. [MEDIUM] CORS: Wildcard Origin [/penggerak/detail/pengelola-korporasi-berskala-global-1883145967]
Ganti wildcard (*) dengan domain spesifik yang diizinkan.

DISCLAIMER

Laporan ini dihasilkan secara otomatis oleh Spencer Web Security Audit Tool. Audit dilakukan pada waktu dan kondisi tertentu; kondisi keamanan website dapat berubah seiring waktu. Hasil audit ini hanya mencakup parameter yang diuji oleh tool dan tidak menggantikan audit keamanan manual oleh professional security expert. Beberapa temuan automated scanner dapat berupa false positive dan harus diverifikasi secara manual sebelum tindakan perbaikan diambil.

Generated by Spencer v2.0 — 21 May 2026